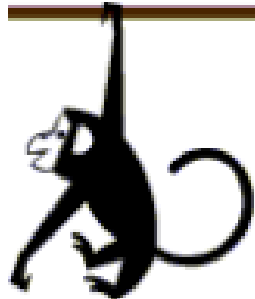


Lab - ARP spoofing

Version 1.0, 1-11-2019, by Ivo Nijhuis

Introduction



In this lab we'll see how we can mislead the ARP protocol, allowing us to redirect network traffic on our local network to our own machine, thus allowing us to eavesdrop on this traffic.

To participate in this lab you'll need Virtual Box and the NE1 Debian VM. You probably already have these set up from the previous labs. If not: download & install!

*Dsniff, retrieved on 1-11-2019 from
<https://www.monkey.org/~dugsong/dsniff/>*

Warning



Intercepting Internet traffic is a potentially illegal activity. Only use these techniques on networks and for devices you own, or after first obtaining permission

Do NOT use Dsniff tools on a network without first obtaining permission.

Installation

We want to set up two Virtual Machines that can communicate with each other: an attacker and a victim machine. This means we'll need VirtualBox to set up a (virtual) private network on your host computer, so that the VM's each can get their own private IP address and can connect to each other.

The first step is to create such a private network in VirtualBox. In the menu, choose `File` and `Preferences`. Go to `Network` and add a new NAT network. Click `OK`.

The next step is to load the downloaded VM into VirtualBox. You may have already done this. If not, start VirtualBox and from the menu choose `File` and `Import Appliance`.

Once the import is complete, change the settings for this Virtual Machine. Under `General`, change the name into: `HvA-NE1-victim`.

Repeat the import or clone your existing VM, to create another VM. Change the name for this VM into `HvA-NE1-attacker`.

Change the `Network` settings for both VMs. They must both be attached to the NAT network that you created earlier. Also, under `Advanced network settings`, make sure the two VMs have different `MAC` addresses. Change the `MAC` address for one of the VMs as needed.

Finally, you'll need the account information: you can login to your VMs using `student / HvA_student` or `root / HvA_root`.

Stage 1: network reconnaissance

Start both the victim and attacker VM, and login to both.

First, we'll work in the **attacker VM**. To prepare for our attack, we first need to find out more information about the local network we are in, and try to identify potential targets.

Answer the following questions, using tools such as: `ip addr show`, `ip route` and `sudo arp -a`.

1. What are the attacker's IP address and MAC address?
2. What is the subnet mask for the local network?
3. What are the IP address and MAC address for the default gateway in this subnet?
4. What is the network interface, connecting your attacker VM to the local network? (It's probably `enp0s3`)

1. Attacker IP address:
Attacker MAC address:
 2. Subnet mask:
 3. Gateway IP address:
Gateway MAC address :
 4. Network interface:

Next, the attacker will scan the network for potential targets, using Nmap:

```
sudo nmap -sn -n -PS <network_to_scan>
```

5. What are the IP address and MAC address for the victim that you discovered?

In a real attack, you would not have direct access to the victim machine. In this case you do, so take the opportunity to use `ip addr show` in the victim machine, to verify you found the correct addresses.

5. Victim IP address:
Victim MAC address:

First try to intercept traffic



There is a command-line alternative to Wireshark available on Linux. It's called `tcpdump` and like Wireshark, we can use it to capture and log network traffic.

Before we can try to intercept the victim's Internet traffic, there must be some traffic for us to capture. A simple way to do this is by having the victim ping a website every few seconds. Go to the **victim VM** and enter:

```
ping -i 5 <your favorite site>
```

Now, we'll see if we can use `tcpdump` to capture the victim's traffic. On the **attacker machine**, enter:

```
sudo tcpdump -i <network_interface> ip host <victim_ip>
```

6. Do you see any results? (No is a valid answer at this point!)

6.

Don't be surprised if you see nothing, that just shows we're not able to intercept any traffic yet! Press CTRL-C to stop `tcpdump`.

Stage 2: ARP spoof attack

The attacker is now prepared to start the attack using ARP spoof. On the **attacker machine**, enter:

```
sudo arpspoof -i <interface> -t <victim_ip> -r <router_ip>
```

You will see that the attacker is now sending out ARP reply messages.

7. According to the ARP reply messages, what is the MAC address for the victim machine?
8. According to the ARP reply messages, what is the MAC address for the default gateway?
9. Who does this MAC address really belong to?

7. MAC address of victim:
8. MAC address of router:
9. Real owner of MAC address:

Second try to intercept traffic



On a LINUX machine, you can switch between different terminal windows. In VirtualBox, this can be done by pressing the host key, together with a function key (*F1, F2, F3...*) The host key is usually the *right-ctrl* key and is shown at the bottom of your VM's window.

On the **attacker VM**, leave the ARP spoof attack running and switch to a different terminal. In the new terminal, once again enter:

```
sudo tcpdump -i <network_interface> ip host <victim_ip>
```



You should now be able to see the network traffic that is being sent by the victim machine. Make a screenshot or picture of your capture to hand in.

Finally, on the victim VM, check what information is in the ARP table. Listing the ARP table will be slow while the machine is processing all the ARP messages it receives, so be patient.

10. What is the MAC address listed for the default gateway?
11. Who does this MAC address really belong to?

10. MAC address of router:
11. Real owner of MAC address:

Defending against ARP poisoning

We can defend against an ARP poisoning attack by running a service that monitors the ARP table for unexpected changes. Fortunately, such a service has been installed on our VM. It is called `arpwatch`.

If `arpwatch` finds any suspicious activity, it will log this to the system logfile, `syslog`.

Check the `syslog` for any issues reported by `arpwatch`:

```
sudo tail -n 20 /var/log/syslog | grep arpwatch
```



Do you see any signs of the attack? Make a screenshot or picture of your results to hand in.

Complete the lab

To wrap up the lab, make a single document containing your answers. Upload your document to DLO.